

# The AI Hydra: When Worms Learn to Think

## A Capability Framework for Autonomous AI-Enabled Offensive Cyber Operations

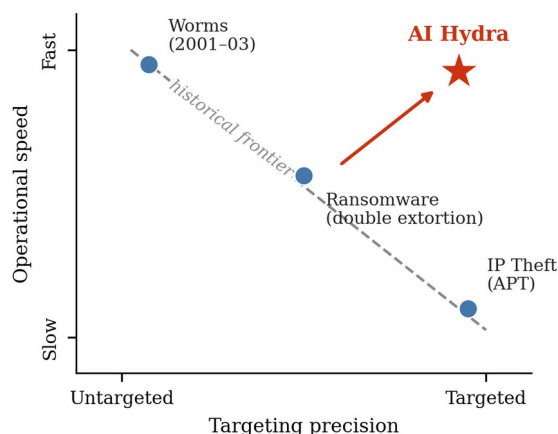
Darren Humphries

Group CISO · AI Hydra Threat Capability Working Group

Presented at Infosec Europe, June 2026 · Living tracker: [greycardinal45.github.io/ai-hydra-tracker](https://greycardinal45.github.io/ai-hydra-tracker)

### Abstract

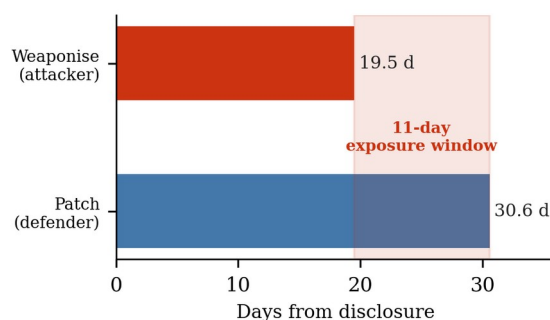
Three classes of cyber threat have, for two decades, occupied separate lanes defined by a single structural trade-off: speed and targeting have been inversely correlated. Worms propagated fast but blindly; advanced persistent threats targeted precisely but slowly; ransomware sits between the two. We argue that autonomous AI collapses this trade-off. The defensive community has already built the enabling architecture—open-source autonomous pentesting systems, machine-speed vulnerability discovery, and AI-driven attack-path planning—so the offensive mirror is now an engineering integration problem, not a research problem. We introduce the AI Hydra: a hypothetical semi-autonomous offensive architecture of four layers—an operator control plane, an AI orchestration engine, a hybrid command-and-control backbone, and a continuously updated tool and TTP layer fed by an adversary software-development lifecycle. We decompose the architecture into a capability framework spanning a seven-phase kill chain, and assess each capability against current public evidence as Exists Today, Partially Exists, or an Engineering Gap. As presented at Infosec Europe (June 2026) the framework tracked 34 capability assessments at 17 / 12 / 5; the associated live intelligence tracker now resolves 32 distinct capabilities at 17 / 11 / 4, with the four remaining gaps all residing in the orchestration layer. We conclude that the threat is asymmetric—buildable today only by Tier 1–2 actors—and that the defensive answer is unchanged in substance but radically compressed in time.



**Figure 1:** The structural trade-off. Speed and targeting have historically been inversely correlated (dashed frontier). Autonomous AI collapses the frontier toward the fast-and-targeted corner.

## 1 Introduction

Begin with three uncomfortable questions for any security leader. How many organisations patch every critical vulnerability within thirty days? How many penetration-test their external and internal estate at least monthly? And what fraction of businesses have reached even a baseline security floor such as Cyber Essentials? The published answers are sobering: attackers weaponise a disclosed vulnerability in a mean of 19.5 days while defenders take 30.6 days to patch—an eleven-day exposure window on average; only 8–12% of organisations test monthly or more often; and roughly 5% of UK businesses hold Cyber Essentials, against 612,000 reporting a breach last year.



**Figure 2:** The exposure window. Mean time-to-weaponise (19.5 d) is now shorter than mean time-to-patch (30.6 d). Sources: Qualys TruRisk; Verizon DBIR.

These gaps existed before generative AI. What AI changes is not the list of required defences but the speed at which an adversary can execute against the gaps the list leaves open. AI is being adopted by defenders and attackers alike, and the same capabilities that accelerate a blue team accelerate a red one. This paper asks a single question: what happens when offensive tooling stops being a static artefact and starts to reason, adapt, and re-arm itself in the field?

Our contributions are three. (i) We formalise the structural trade-off between speed and targeting that has historically separated worms, ransomware, and intellectual-property theft, and argue that autonomous AI collapses it. (ii) We present the AI Hydra, a four-layer reference architecture for a semi-autonomous offensive campaign, and decompose it into a capability framework over a seven-phase kill chain. (iii) We assess every capability against current public evidence, maintain the assessment as a living intelligence tracker, and show that the residual barriers are narrow, orchestration-layer integration problems rather than research-grade unknowns.

## 2 Background: The Three Lanes

For twenty years, offensive cyber activity has clustered into three motivations, each with its own method and a shared structural constraint.

**Worms (2001–2003).** Code Red, Nimda, and SQL Slammer optimised for maximum propagation with zero targeting and no monetisation. They were fast and indiscriminate.

**Ransomware and double extortion.** Modern ransomware steals before it encrypts—data theft is now the playbook, not a side effect. Its tooling overlaps 70–80% with nation-state APT tradecraft, and double extortion has begun to close the gap between speed and value.

**Intellectual-property theft.** State-sponsored campaigns pursue technological superiority, dwelling for months or years inside a target where the value of access compounds over time. They are precisely targeted but slow.

**The structural trade-off.** Across all three lanes, speed and targeting have been inversely correlated (Figure 1): a campaign could be fast or precise, but not both. Double extortion has nudged at this frontier; autonomous AI threatens to erase it.

## 3 The Parallel That Already Exists

The central observation of this work is that the defensive community has already built the offensive architecture—it simply points the other way. Autonomous capability is no longer hypothetical on the defensive side of the fence.

Open-source and commercial systems already perform autonomous offensive tasks. PentAGI is a fully autonomous

multi-agent penetration-testing system with specialised roles [8]. XBOW became the first autonomous system to reach number one on the HackerOne global leaderboard, executing over a thousand vulnerabilities [9], and Horizon3's NodeZero has run 180,000-plus autonomous pentests with LLM-driven high-value-target prioritisation [5, 6, 7]. DARPA's AIXCC final demonstrated machine-speed discovery and patching at scale [10], and ARTEMIS beat nine of ten human pentesters on a live enterprise network [13]. Anthropic's Mythos preview found zero-days in every major operating system and browser and was judged too capable to release [11].

**Nation-state adoption is already in evidence.** A Chinese state-sponsored group automated 80–90% of a campaign against roughly thirty targets using jailbroken frontier models [12, 21], and frontier-model offensive capability has climbed from near-zero to a 'High' threshold in twelve months [15, 22]. The offensive mirror of the defensive architecture is therefore an engineering problem, not a research problem.

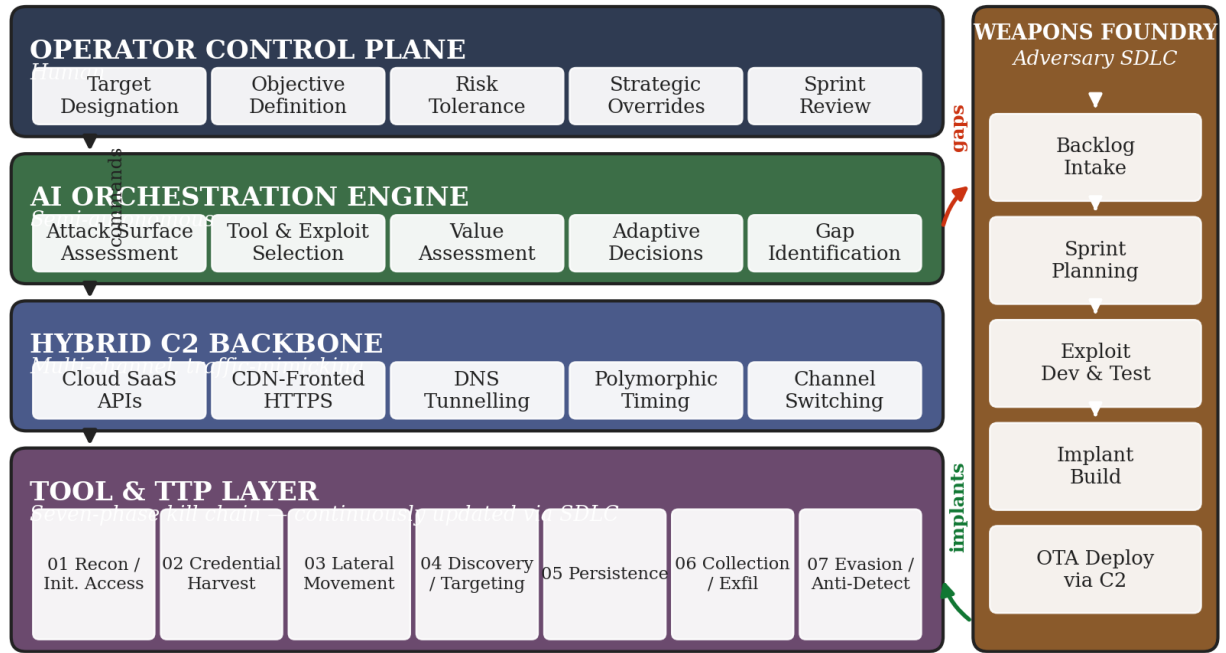
## 4 The Hydra Thesis: Constrained AI as Weapon

The thesis is a single question. What if malware could propagate like a worm, think like a pentester, and steal like an APT—simultaneously? The objection is that fully autonomous, internet-scale target selection exceeds current capability. That objection holds only for the unconstrained problem.

**The barrier drops sharply when the problem is constrained.** An unconstrained instruction—'find valuable targets across the entire internet and steal their IP'—requires autonomous target selection, value assessment, and navigation that exceeds today's systems. A constrained instruction—'here is the target, here are your exploits, find the way in, and locate files matching these keywords'—is a capture-the-flag exercise with an objective, and it is feasible now. The human operator supplies the constraints the AI cannot yet generate; the AI supplies the speed and adaptation the human cannot.

## 5 Operational Architecture

Figure 3 presents the AI Hydra as four stacked layers with a feedback-driven weapons foundry. The design is deliberately semi-autonomous: a human sets intent and the machine executes tactics.



**Figure 3:** The AI Hydra operational architecture. A human operator sets intent (top); an AI orchestration engine makes tactical decisions; a hybrid C2 backbone mimics legitimate traffic; and a seven-phase tool and TTP layer is continuously re-armed by an adversary-SDLC weapons foundry (right) via a gaps-up / implants-down feedback loop.

**Operator control plane (human).** Target designation, objective definition, risk tolerance, strategic overrides, and sprint review. The operator relinquishes tactical control once the campaign is launched.

**AI orchestration engine (semi-autonomous).** Attack-surface assessment, tool and exploit selection, value assessment, adaptive decisions, and gap identification. This layer is where the residual engineering gaps concentrate.

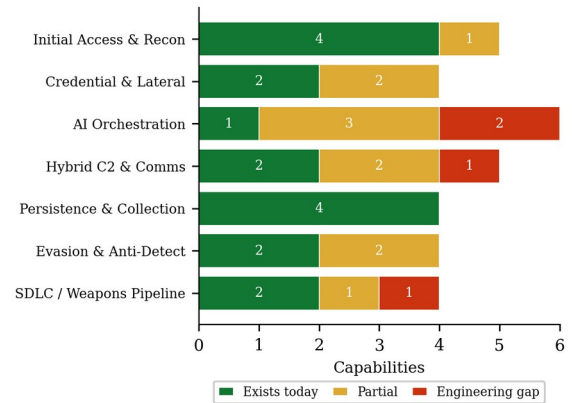
**Hybrid C2 backbone.** Multi-channel command and control that mimics legitimate traffic—cloud SaaS APIs, CDN-fronted HTTPS, DNS tunnelling, polymorphic timing, and dynamic channel switching [18, 19, 20].

**Tool and TTP layer.** A seven-phase kill chain—recon and initial access, credential harvest, lateral movement, discovery and targeting, persistence, collection and exfiltration, and evasion—continuously updated by the foundry.

**Weapons foundry (adversary SDLC).** A backlog-to-deployment pipeline—intake, sprint planning, exploit development and test, implant build, and over-the-air deployment via C2. The field agent pushes capability gaps up; the foundry returns implants down. The automation of this loop is the framework's defining open problem.

## 6 Capability Assessment

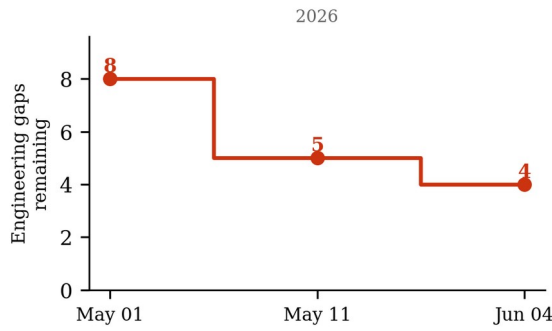
We decompose the architecture into discrete capabilities along the seven-phase kill chain and assess each against current public evidence at three maturity levels: Exists Today (demonstrated in defensive tools, commodity malware, or documented APT tradecraft), Partially Exists (proven in research or partly demonstrated in the wild), and Engineering Gap (not yet demonstrated). Figure 4 summarises the distribution; Table 1 gives the capability-level detail with live evidence.



**Figure 4:** Capability maturity by kill-chain phase (live tracker). Persistence and collection is fully realised; the residual gaps concentrate in AI orchestration.

**Reconciliation note.** As presented at Infosec Europe the framework reported 34 capability assessments split 17 / 12 / 5. The live tracker subsequently resolved two assessments on new evidence—environment value assessment moved from Gap to Partial on the Ransomware 3.0 proof-of-concept [27], and selective data identification moved from Partial to Exists on in-the-wild PromptSteal and QuietVault activity [26]—resolving to 32 distinct capabilities at 17 / 11 / 4. The four remaining gaps are all orchestration-layer integration problems.

**Velocity.** The assessment is not static. Between 1 May and 4 June 2026 the count of hard engineering gaps fell from eight to four (Figure 5), three of them closing in a single three-week window following the GTIG AI Threat Tracker disclosures [1, 2].



**Figure 5:** Engineering gaps remaining over time. Eight gaps at the initial assessment fell to four within five weeks as in-the-wild evidence accumulated.

**The four remaining gaps.** Selective IP targeting under live defensive pressure; legitimate-user traffic mimicry [25]; the automated field-to-foundry feedback loop; and full adaptive evasion against active SOC hunting. Each is an integration challenge within or around the orchestration engine, not a missing primitive.

**Table 1:** Capability assessment across the seven-phase kill chain. Status reflects the live intelligence tracker; ▲ marks a capability advanced since the Infosec Europe presentation. Bracketed numbers reference the intelligence registry.

| Capability                                | Status  | Evidence (live tracker)                                                                      |
|-------------------------------------------|---------|----------------------------------------------------------------------------------------------|
| <b>Initial Access &amp; Recon</b>         |         |                                                                                              |
| Autonomous vulnerability scanning         | Exists  | XBOW, Horizon3 NodeZero, PentAGI, Node4 [8, 9]                                               |
| Autonomous exploit execution              | Exists  | XBOW (1,060 vulns); NodeZero (180k+ pentests) [5, 9]                                         |
| AI-generated spearphishing                | Exists  | Documented misuse across multiple LLMs [23]                                                  |
| Zero-day discovery                        | Exists  | Anthropic Mythos — every major OS and browser [11]                                           |
| ▲ Zero-day weaponisation (logic flaws)    | Partial | GTIG — first documented AI-developed zero-day [1]                                            |
| <b>Credential &amp; Lateral Movement</b>  |         |                                                                                              |
| Mimikatz / LSASS / Kerberoasting          | Exists  | Commodity tooling — identical across ransomware and APT                                      |
| Living off the land (PS, WMI, PsExec)     | Exists  | Standard TTP — no new tooling required [20]                                                  |
| AI-driven lateral movement                | Partial | DARPA AIXCC; NodeZero attack paths; PentAGI [6, 10, 13]                                      |
| Autonomous privilege escalation           | Partial | Mythos kernel privesc; NodeZero domain-admin paths [7, 11]                                   |
| <b>AI Orchestration</b>                   |         |                                                                                              |
| Attack surface assessment                 | Exists  | Horizon3, XBOW, PentAGI, Node4 [6, 8, 9]                                                     |
| Real-time tool selection                  | Partial | PentAGI multi-agent; PROMPTSPY; NodeZero HVT [2, 8]                                          |
| ▲ Environment value assessment            | Partial | Ransomware 3.0 POC (NYU Tandon) — host-aware objective selection [27]                        |
| CTF objective matching                    | Partial | Solvers exist — not real-world IP targeting [31]                                             |
| Selective IP targeting (capture-the-flag) | Gap     | Held at gap; evidence accumulating but undemonstrated under live defensive pressure [26, 27] |
| Adaptive evasion (vs SOC hunting)         | Gap     | Not demonstrated at enterprise scale [30]                                                    |
| <b>Hybrid C2 &amp; Comms</b>              |         |                                                                                              |
| C2 via legitimate cloud services          | Exists  | APT34/35; Mini Shai-Hulud (GitHub API) [4, 18, 19]                                           |
| Domain fronting / CDN abuse               | Exists  | Commodity technique since 2017                                                               |
| Polymorphic timing                        | Partial | PROMPTFLUX — concept proven in field [14]                                                    |
| ▲ Dynamic C2 rotation                     | Partial | PROMPTSPY — runtime infrastructure updates [2]                                               |
| Legitimate user traffic mimicry           | Gap     | Theoretical — needs target-environment training data [25]                                    |
| <b>Persistence &amp; Collection</b>       |         |                                                                                              |
| Multi-mechanism persistence               | Exists  | Standard APT + Mini Shai-Hulud (IDE, OS, registry, repos) [4, 28]                            |
| ▲ Selective data identification by LLM    | Exists  | PromptSteal (APT28) + QuietVault — in the                                                    |

|                                           |         |                                                                |
|-------------------------------------------|---------|----------------------------------------------------------------|
|                                           |         | wild [26]                                                      |
| Slow exfiltration via legitimate channels | Exists  | APT standard + Shai-Hulud (GitHub GraphQL API) [4]             |
| Ongoing evolving IP collection            | Exists  | APT campaigns — months to years duration                       |
| <b>Evasion &amp; Anti-Detection</b>       |         |                                                                |
| Polymorphic code mutation                 | Exists  | 76% of detected malware (2025/2026) [16, 24]                   |
| EDR-specific evasion development          | Exists  | Standard cat-and-mouse — new bypasses monthly                  |
| ▲ AI real-time evasion adaptation         | Partial | PROMPTSPY overlay evasion + CANFAIL / LONGSTREAM decoys [2, 3] |
| Autonomous log cleaning                   | Partial | Scripts exist — AI-contextual cleanup undemonstrated           |
| <b>SDLC / Weapons Pipeline</b>            |         |                                                                |
| Exploit development teams                 | Exists  | Nation-state programmes — standard operating model             |
| AI-assisted exploit development           | Exists  | LLM misuse documented by Anthropic, Google, OpenAI [15, 22]    |
| Automated field-to-foundry feedback loop  | Gap     | The integration gap — no autonomous request pipeline           |
| OTA implant deployment via C2             | Partial | C2 frameworks support module push — AI-triggered is new        |

Maturity key: *Exists Today (green) · Partially Exists (amber) · Engineering Gap (red)*. ▲ = advanced since Infosec Europe, June 2026.

**Component reference.** Each capability is examined below —what it is, why it matters within the Hydra architecture, and, according to its maturity, either the defensive intervention available today or the engineering gap that remains. Capabilities are grouped by kill-chain phase and ordered as in Table 1.

## 6.1 Initial Access & Recon

### Autonomous vulnerability scanning — Exists Today

**What it is.** AI systems that enumerate a target's external and internal attack surface and identify exploitable weaknesses without a human operator. **Why it matters.** The opening move of every campaign. Automating it removes the reconnaissance bottleneck and lets the Hydra begin each engagement at machine speed. **Evidence.** XBOW, Horizon3 NodeZero, PentAGI, Node4. [8, 9] **Defensive intervention.** Assume continuous, machine-speed scanning. Shrink and inventory the external attack surface (EASM), patch internet-facing systems in days not weeks, and move to continuous security validation rather than annual testing.

### Autonomous exploit execution — Exists Today

**What it is.** Selecting and firing the correct exploit against an identified weakness autonomously. **Why it matters.** Converts a finding into access—the bridge from reconnaissance to foothold. XBOW and NodeZero demonstrate it at scale. **Evidence.** XBOW (1,060 vulns); NodeZero (180k+ pentests). [5, 9] **Defensive intervention.** Prioritise patching of exploitable, internet-facing CVEs; deploy virtual patching/WAF for the exposure window; segment so a single foothold cannot cascade; detect exploitation chains behaviourally.

### AI-generated spearphishing — Exists Today

**What it is.** LLM-crafted, target-tailored phishing produced at scale. **Why it matters.** Still the dominant initial-access vector; AI removes the language and quality tells defenders historically relied upon. **Evidence.** Documented misuse across multiple LLMs. [23] **Defensive intervention.** Deploy phishing-resistant MFA (FIDO2/passkeys), not OTP; enforce DMARC/DKIM/SPF; enable fast user reporting and takedown.

Reduce dependence on user vigilance—assume the lure is convincing.

### Zero-day discovery — Exists Today

**What it is.** AI discovering previously unknown vulnerabilities. Mythos found zero-days in every major operating system and browser and was judged too capable to release. **Why it matters.** Defeats patch-based defence entirely for the lifetime of the unknown flaw. **Evidence.** Anthropic Mythos — every major OS and browser. [11] **Defensive intervention.** Lean on controls that do not depend on knowing the specific CVE: defence-in-depth, least privilege, segmentation, and exploit-mitigation technology (ASLR/CFG, memory-safe languages).

### ▲ Zero-day weaponisation (logic flaws) — Partially Exists

**What it is.** Turning a discovered logic flaw—an authentication bypass or business-logic error—into a working exploit autonomously. **Why it matters.** Discovery without weaponisation is inert; this closes the discover-to-exploit pipeline for the logic-flaw class. **Evidence.** GTIG — first documented AI-developed zero-day. [1] **Engineering gap.** Memory-corruption weaponisation still requires human expertise; only logic-class flaws are within autonomous reach today. Defensively: secure-by-design authentication and authorisation, server-side validation, and abuse-case testing.

## 6.2 Credential & Lateral Movement

### Mimikatz / LSASS / Kerberoasting — Exists Today

**What it is.** Commodity credential-theft tooling: LSASS memory dumping, Kerberos ticket extraction and offline cracking. **Why it matters.** Credentials are the currency of lateral movement; this tooling is identical across ransomware and nation-state actors. **Evidence.** Commodity tooling — identical across ransomware and APT. **Defensive intervention.** Enable Credential Guard / LSASS protection; adopt a tiered administration model; detect Kerberoasting via anomalous TGS requests; use gMSA and long, managed service-account secrets.

### Living off the land (PS, WMI, PsExec) — Exists Today

**What it is.** Using built-in operating-system tools—PowerShell, WMI, PsExec—to execute and move laterally, leaving no



malware artefacts. **Why it matters.** Evades file-based detection and needs no custom tooling, making it the default movement technique. **Evidence.** Standard TTP — no new tooling required. [20] **Defensive intervention.** Enable PowerShell script-block logging and AMSI; constrained language mode; application control (WDAC); behavioural analytics that flag legitimate tools used in illegitimate sequences.

#### AI-driven lateral movement — Partially Exists

**What it is.** An AI autonomously choosing pivot points and next hops through a network. **Why it matters.** Lateral movement is where human pentesters add the most judgement; automating it removes the operator from the loop mid-campaign. **Evidence.** DARPA AIXCC; NodeZero attack paths; PentAGI. [6, 10, 13] **Engineering gap.** Demonstrated in structured and sandboxed environments; not yet robust against a live, instrumented enterprise network. Defensively: micro-segmentation, identity-based access, and east-west traffic analytics.

#### Autonomous privilege escalation — Partially Exists

**What it is.** Self-directed elevation from a foothold to administrator or domain-administrator. **Why it matters.** Privilege is the precondition for collection, persistence, and impact. **Evidence.** Mythos kernel privileges; NodeZero domain-admin paths. [7, 11] **Engineering gap.** Field-tested in components but not reliably autonomous end-to-end. Defensively: least privilege, just-in-time admin, LAPS, a tiered AD model, and prompt patching of privilege-escalation CVEs.

### 6.3 AI Orchestration

#### Attack surface assessment — Exists Today

**What it is.** Building a model of the target's exposed surface in order to plan against it. **Why it matters.** The orchestration engine's situational awareness; every downstream decision depends on it. **Evidence.** Horizon3, XBOW, PentAGI, Node4. [6, 8, 9] **Defensive intervention.** Reduce and monitor the attack surface; deploy deception (honeypots, decoy services) to poison the attacker's model; maintain continuous external-attack-surface management.

#### Real-time tool selection — Partially Exists

**What it is.** The orchestrator choosing the right tool or exploit for the current context on the fly. **Why it matters.** Adaptivity is the difference between a static script and a thinking adversary. **Evidence.** PentAGI multi-agent; PROMPTSPY; NodeZero HVT. [2, 8] **Engineering gap.** Works inside constrained multi-agent setups; brittle under novel or actively defended conditions. Defensively: unpredictable, defended environments raise attacker cost, and rapid tool-switching is itself a behavioural signal.

#### ▲ Environment value assessment — Partially Exists

**What it is.** The AI judging host and network context—personal computer versus server versus industrial controller—to choose its objective and the highest-value files. **Why it matters.** Targeting intelligence: it lets one implant behave appropriately across a diverse estate without per-target coding. **Evidence.** Ransomware 3.0 POC (NYU Tandon) — host-aware objective selection. [27] **Engineering gap.** Demonstrated only at proof-of-concept grade in a benign sandbox, not in the field under defensive pressure. Defensively: data classification and DLP make 'value' harder to infer; honeyfiles mislead the assessment.

#### CTF objective matching — Partially Exists

**What it is.** Matching discovered assets to a defined objective —'find files matching these keywords'—in the manner of a capture-the-flag solver. **Why it matters.** This is the constrained-problem formulation that makes the entire thesis feasible today (Section 4). **Evidence.** Solvers exist — not real-world IP targeting. [31] **Engineering gap.** CTF solvers exist; real-world

intellectual-property objective matching under noise and active defence is undemonstrated. Defensively: keep crown-jewel data segmented, classified, and monitored, and reduce keyword-discoverability.

#### Selective IP targeting (capture-the-flag) — Engineering Gap

**What it is.** Autonomously locating and exfiltrating mission-specified intellectual property under live defensive pressure. **Why it matters.** The monetisation and impact endpoint of the IP-theft lane—the capability that would make the Hydra strategically dangerous. **Evidence.** Held at gap; evidence accumulating but undemonstrated under live defensive pressure. [26, 27] **Engineering gap.** Held deliberately at gap: file-value selection in a benign sandbox is not mission-objective exfiltration against an alert SOC. One of the four hard gaps. Defensively: DLP, egress control, and data-centric monitoring.

#### Adaptive evasion (vs SOC hunting) — Engineering Gap

**What it is.** Real-time adaptation to active threat-hunting and incident response at enterprise scale. **Why it matters.** It determines whether the Hydra survives contact with a competent, adapting SOC. **Evidence.** Not demonstrated at enterprise scale. [30] **Engineering gap.** Not demonstrated at enterprise scale; the contest is against humans who also adapt. One of the four hard gaps. The defensive moat is precisely this human adaptivity—invest in threat hunting and detection engineering.

### 6.4 Hybrid C2 & Comms

#### C2 via legitimate cloud services — Exists Today

**What it is.** Command-and-control routed through trusted SaaS platforms—OneDrive, GitHub, Dropbox. **Why it matters.** Blends with normal enterprise traffic and defeats domain and IP blocklists. **Evidence.** APT34/35; Mini Shai-Hulud (GitHub API). [4, 18, 19] **Defensive intervention.** Inspect egress via CASB or proxy; baseline and anomaly-detect cloud-service API usage and volumes; restrict unsanctioned SaaS.

#### Domain fronting / CDN abuse — Exists Today

**What it is.** Concealing C2 behind a reputable CDN domain so the apparent destination is trusted. **Why it matters.** Adds a second layer of traffic camouflage on top of cloud-service abuse. **Evidence.** Commodity technique since 2017. **Defensive intervention.** Perform TLS inspection where feasible; detect SNI / host-header mismatches; cooperate with CDN providers; apply egress allow-listing.

#### Polymorphic timing — Partially Exists

**What it is.** Varying C2 beacon timing to defeat cadence-based detection. **Why it matters.** Beacon periodicity is a classic detection signal; randomising it blinds that analytic. **Evidence.** PROMPTFLUX — concept proven in field. [14] **Engineering gap.** Concept proven (PROMPTFLUX) but not yet a robust standard. Defensively: jitter-tolerant beaconing analytics, long-baseline behavioural detection, and network-metadata analysis.

#### ▲ Dynamic C2 rotation — Partially Exists

**What it is.** Runtime switching of C2 infrastructure and channels. **Why it matters.** Survives takedowns and blocklisting, giving long campaigns resilience. **Evidence.** PROMPTSPY — runtime infrastructure updates. [2] **Engineering gap.** Demonstrated in mobile malware (PROMPTSPY); not yet generalised. Defensively: rapid IOC sharing and infrastructure tracking, plus behavioural rather than indicator-based detection.

#### Legitimate user traffic mimicry — Engineering Gap

**What it is.** Shaping C2 to statistically resemble the specific target's own normal user traffic. **Why it matters.** The endgame

of C2 stealth—defeating anomaly detection by being indistinguishable from baseline. **Evidence.** Theoretical — needs target-environment training data. [25] **Engineering gap.** Theoretical; it requires per-target training data the adversary does not yet harvest and apply. One of the four hard gaps. Network baselining and UEBA are exactly why behavioural detection still works.

## 6.5 Persistence & Collection

### Multi-mechanism persistence — **Exists Today**

**What it is.** Redundant persistence spread across IDE, operating system, registry, and code repositories. **Why it matters.** Survivability: removing one foothold does not evict the adversary. **Evidence.** Standard APT + Mini Shai-Hulud (IDE, OS, registry, repos). [4, 28] **Defensive intervention.** Audit persistence mechanisms (autoruns, scheduled tasks, services); use EDR persistence detection and integrity monitoring; rehearse assume-breach eviction playbooks.

### ▲ Selective data identification by LLM — **Exists Today**

**What it is.** An on-host LLM deciding what data is worth taking. PromptSteal generates collection commands at runtime; QuietVault hunts secrets. **Why it matters.** Turns mass exfiltration into surgical, high-value collection—more bandwidth-efficient and stealthier. **Evidence.** PromptSteal (APT28) + QuietVault — in the wild. [26] **Defensive intervention.** Classify data and deploy DLP; manage secrets in a vault with no plaintext credentials on hosts; seed honeytokens; monitor egress volumes.

### Slow exfiltration via legitimate channels — **Exists Today**

**What it is.** Low-and-slow data theft through trusted APIs such as the GitHub GraphQL endpoint. **Why it matters.** Stays below volumetric DLP thresholds and inside trusted channels. **Evidence.** APT standard + Shai-Hulud (GitHub GraphQL API). [4] **Defensive intervention.** Apply egress DLP with low-and-slow analytics, monitor API egress, and detect data-access anomalies rather than relying on volume alone.

### Ongoing evolving IP collection — **Exists Today**

**What it is.** Persistent collection over months to years that adapts as the target's intellectual property evolves. **Why it matters.** The IP-theft lane's value compounds with dwell time. **Evidence.** APT campaigns — months to years duration. **Defensive intervention.** Reduce dwell time through detection maturity; run periodic threat hunts; monitor crown-jewel repositories; operate on an assumption of long-term compromise.

## 6.6 Evasion & Anti-Detection

### Polymorphic code mutation — **Exists Today**

**What it is.** Self-modifying code that changes its signature on every instance. **Why it matters.** Defeats static and signature-based antivirus outright. **Evidence.** 76% of detected malware (2025/2026). [16, 24] **Defensive intervention.** Favour behavioural EDR over signatures, scan memory, and apply anomaly detection—assume the binary is unique every time.

### EDR-specific evasion development — **Exists Today**

**What it is.** Bypasses tailored to defeat specific EDR products. **Why it matters.** EDR is the primary endpoint control, so evading it is high-value to the attacker. **Evidence.** Standard cat-and-mouse — new bypasses monthly. **Defensive intervention.** Build defence-in-depth beyond EDR (network, identity, logs); enable tamper protection; forward EDR telemetry to the SIEM so endpoint blindness is caught centrally.

### ▲ AI real-time evasion adaptation — **Partially Exists**

**What it is.** Runtime adaptation of evasion behaviour based on the defended environment, including AI-generated decoy code to mislead analysts. **Why it matters.** Static evasion is brittle; adaptive evasion responds to whatever defences it encounters. **Evidence.** PROMPTSPY overlay evasion + CANFAIL / LONGSTREAM decoys. [2, 3] **Engineering gap.** Demonstrated in narrow cases (PROMPTSPY, CANFAIL/LONGSTREAM), not as general adaptive evasion (cf. the orchestration gap). Defensively: deception, threat hunting, and multi-layer telemetry correlation.

### Autonomous log cleaning — **Partially Exists**

**What it is.** AI-driven contextual removal of forensic traces. **Why it matters.** Defeats post-incident investigation and erodes detection. **Evidence.** Scripts exist — AI-contextual cleanup undemonstrated. **Engineering gap.** Scripts exist; contextual, AI-driven cleanup is undemonstrated. Defensively: immutable and off-host logging—forward logs to the SIEM in real time so they leave the host before they can be cleaned.

## 6.7 SDLC / Weapons Pipeline

### Exploit development teams — **Exists Today**

**What it is.** Organised human exploit-development capability—the existing 'foundry'. **Why it matters.** The supply side of the weapons pipeline, and the function the automated foundry aims to replace. **Evidence.** Nation-state programmes — standard operating model. **Defensive intervention.** Not directly defensible, but it strengthens the case for memory-safe code, exploit mitigations, and reducing exploitable surface so each exploit costs more to produce.

### AI-assisted exploit development — **Exists Today**

**What it is.** LLMs accelerating the creation of exploits. **Why it matters.** Compresses the foundry's cycle time—more exploits, produced faster. **Evidence.** LLM misuse documented by Anthropic, Google, OpenAI. [15, 22] **Defensive intervention.** Maintain the same hardening posture, and treat AI-provider guardrails and abuse monitoring as an upstream control that raises the attacker's cost.

### Automated field-to-foundry feedback loop — **Engineering Gap**

**What it is.** The field agent autonomously requesting new capability and the foundry building and returning it, closed-loop, with no human in the path. **Why it matters.** This loop is what would make the Hydra a self-improving organism rather than a static toolkit—the framework's defining capability. **Evidence.** The integration gap — no autonomous request pipeline. **Engineering gap.** No autonomous request-to-build-to-deploy pipeline exists. It is the single most important of the four gaps; its absence is the current strategic reprieve, and the C2 channels it would require (Phase 6) are the detection lever.

### OTA implant deployment via C2 — **Partially Exists**

**What it is.** Pushing new or updated implant modules over the air via the C2 channel. **Why it matters.** The delivery half of the foundry loop; without it the foundry cannot re-arm the field agent. **Evidence.** C2 frameworks support module push — AI-triggered is new. **Engineering gap.** C2 frameworks already support module push; the new element is AI-triggered, autonomous deployment. Defensively: C2 detection (Phase 6), application control, and egress monitoring on update channels.

## 7 Who Can Build This

The threat is not uniform. The capability to integrate the architecture is, today, the preserve of the best-resourced actors.

**Tier 1–2 — nation-states and state-adjacent groups.** Can build this now. China has demonstrated 80–90% autonomous operations, and every AIXCC competition system is open

source [10, 12]. For these actors the remaining gaps are narrow and closing.

**Tier 3–5 — criminal groups, hackers, opportunists.** Cannot build this yet. The same ransomware-and-BEC threat model still applies, and the fundamentals remain the answer. Agent-hijacking—stealing an orchestration layer rather than building one—is the more realistic near-term path for this tier [29, 30].

**Asymmetry.** The organisations already most at risk—defence supply chain, critical national infrastructure, high-value IP holders, and energy, oil, and maritime operators—face an asymmetric capability jump, while everyone else stays in the same threat model. That is more alarming, not less.

## 8 The Speed Problem and Recommendations

AI compresses every defensive timeline. A thirty-day patch cycle was slow when exploits took weeks; it is untenable when discovery takes hours. Annual penetration testing is not the same sport as an adversary whose AI tests daily. And 95% of organisations have not reached the security floor, even though the overwhelming majority of incidents remain preventable [17]. The fundamentals are not changing; the speed at which they must be executed is.

**Monday morning—the same list, faster.** (1) Compress the patch cycle to fourteen days. (2) Move to continuous security validation rather than point-in-time testing. (3) Segment networks. (4) Enforce MFA everywhere. (5) Invest in behavioural, not signature, detection. (6) Test recovery, not just backups. (7) Reach the floor—Cyber Essentials Plus keeps an organisation honest.

## 9 Related Work

Our framework synthesises three strands. Autonomous offensive systems—XBOW, NodeZero, PentAGI, ARTEMIS, and the AIXCC finalists—establish that machine-speed discovery, exploitation, and attack-path planning exist today [8, 9, 10, 13]. In-the-wild AI malware—Ransomware 3.0, PROMPTSPY, PROMPTFLUX, PromptSteal, and the self-propagating Mini Shai-Hulud and Miasma supply-chain worms—demonstrates LLM-driven orchestration, evasion, and collection in production [2, 4, 14, 26, 27, 28]. Capability-threshold reporting from GTIG, OpenAI, Anthropic, and UK AISI tracks the underlying trajectory [15, 21, 22, 31]. The AI Hydra's contribution is to unify these into one architecture and a continuously maintained, evidence-linked capability assessment.

## 10 Conclusion

The three lanes are converging. The defences have not changed—patch, validate, segment, authenticate, detect, recover, and reach the floor remain the answer for whatever comes next. What is changing is the urgency. The offensive architecture is no longer a research question; it is an integration question, and the integration gaps are closing measured in weeks. Defenders should plan accordingly: not for a new list, but for the same list executed at machine speed.

## References

- [1] Google Threat Intelligence Group. “First AI-developed zero-day exploit identified.” 2026-05-11. <https://cloud.google.com/blog/topics/threat-intelligence/ai-vulnerability-exploitation-initial-access>
- [2] GTIG / ESET. “PROMPTSPY: autonomous Android malware with Gemini C2.” 2026-05-11. <https://cloud.google.com/blog/topics/threat-intelligence/ai-vulnerability-exploitation-initial-access>
- [3] GTIG. “CANFAIL / LONGSTREAM: AI-generated decoy code for analyst evasion.” 2026-05-11. <https://cloud.google.com/blog/topics/threat-intelligence/ai-vulnerability-exploitation-initial-access>
- [4] StepSecurity / Microsoft Security / Wiz / Snyk / Upwind / NHS England CSOC. “Mini Shai-Hulud Wave 5: first cross-registry self-propagating supply chain worm.” 2026-05-11. <https://stepsecurity.io/blog/mini-shai-hulud-is-back>
- [5] Deloitte Technology Fast 500 / Inc. 5000 / Horizon3.ai. “Horizon3.ai: 3rd fastest growing company in North America — 19,939% revenue growth.” 2026-03-19. <https://horizon3.ai/news/press-release/horizon3-arr-growth-nodezero/>
- [6] Horizon3.ai. “NodeZero High-Value Targeting: LLM-driven attack path prioritisation.” 2026-01-20. <https://horizon3.ai/intelligence/blogs/nodezero-high-value-targeting-attacker-prioritization/>
- [7] Horizon3.ai. “NodeZero cloud pentesting: autonomous on-prem to Azure Entra ID Global Admin.” 2026-03-01. <https://horizon3.ai/nodezero/cloud-pentesting/>
- [8] VXControl / Help Net Security. “PentAGI: open-source fully autonomous multi-agent pentesting system.” 2026-04-22. <https://github.com/vxcontrol/pentagi>
- [9] XBOW / CyberScoop. “XBOW: first autonomous system to reach #1 on HackerOne global leaderboard.” 2025-06-15. <https://xbow.com/blog>
- [10] DARPA. “DARPA AIXCC: \$4M grand prize — autonomous systems find and patch vulnerabilities at machine speed.” 2025-08-15. <https://aicyberchallenge.com>
- [11] Anthropic / UK AISI / Project Glasswing. “Anthropic Mythos Preview: zero-days in every major OS and browser — too capable to release.” 2026-04-07. <https://www.anthropic.com/glasswing>
- [12] Anthropic. “Chinese state-sponsored group automates 80-90% of cyber campaign via jailbroken Claude Code.” 2025-11-15.
- [13] Stanford University / Carnegie Mellon / Gray Swan AI. “ARTEMIS: autonomous AI beats 9 of 10 human pentesters on live enterprise network.” 2025-12-15. <https://arxiv.org/abs/2512.09882>
- [14] GTIG. “PROMPTFLUX: LLM-driven runtime malware code rewriting to evade specific EDR signatures.” 2026-02-12. <https://cloud.google.com/blog/topics/threat-intelligence/distillation-experimentation-integration-ai-adversarial-use>
- [15] OpenAI Preparedness Framework. “GPT 5.3-Codex reaches 'High' cybersecurity threshold on OpenAI Preparedness Framework.” 2026-02-01.
- [16] Cloud Security Alliance. “Cloud Security Alliance defines 'vibeware': AI-assisted malware industrialisation.” 2026-03-01.
- [17] HarfangLab. “HarfangLab 2026 Threatscape: 188% YoY supply chain attack increase and systematic automation prediction.” 2026-05-20. <https://harfanglab.io/insidethelab/2026-cyber-threatscape-predictions/>
- [18] CrowdStrike / Unit 42 / GTIG. “APT34 (OilRig): C2 via OneDrive and Exchange Online — legitimate cloud channel abuse.” 2025-06-01.
- [19] CrowdStrike / Mandiant / GTIG. “APT35 (Charming Kitten): C2 via Dropbox, Google Drive, and IPFS.” 2025-06-01.
- [20] CISA / NCSC / CrowdStrike. “MuddyWater: C2 via legitimate remote administration tools.” 2025-06-01.
- [21] Google Threat Intelligence Group. “GTIG: Chinese threat actor GTG-1002 achieves 80% autonomous operation using LLMs.” 2026-05-11. <https://cloud.google.com/blog/topics/threat-intelligence/ai-vulnerability-exploitation-initial-access>
- [22] Irregular / Anthropic / UK AISI. “Frontier model offensive security capability: near-zero to 73% success in 12 months.” 2026-04-15.
- [23] IntelligenceX. “80% of ransomware attacks now incorporate AI at some stage of the operation.” 2025-12-01.
- [24] Multiple sources (2025/2026). “76% of detected malware exhibits AI-driven polymorphic behaviour.” 2025-12-01.
- [25] Lumu. “Lumu prediction: AI-C2 frameworks with corporate telemetry fine-tuning.” 2025-12-01.
- [26] GTIG. “PromptSteal (APT28) and QuietVault — in-the-wild LLM-driven data collection.” 2025-11-05. <https://cloud.google.com/blog/topics/threat-intelligence/distillation-experimentation-integration-ai-adversarial-use>
- [27] NYU Tandon (arXiv 2508.20444). “Ransomware 3.0 — self-composing, LLM-orchestrated ransomware POC.” 2025-08-28. <https://arxiv.org/abs/2508.20444>
- [28] Aikido Security / Unit 42 / Upwind. “Miasma — Red Hat npm scope compromised by commoditised Mini Shai-Hulud variant.” 2026-06-01.



<https://www.aikido.dev/blog/red-hat-npm-packages-compromised-credential-stealing-worm>

- [29] Cyera. “Claw Chain — four chained CVEs hijack OpenClaw autonomous AI agents.” 2026-05-18.  
<https://www.cyera.com/blog/claw-chain-cyera-research-unveil-four-chainable-vulnerabilities-in-openclaw>
- [30] CrowdStrike 2026 Global Threat Report / OWASP Agentic Top 10 / McKinsey red-team. “Agent hijacking — stealing the orchestration layer rather than building it.” 2026-02-01.  
<https://venturebeat.com/security/adversaries-hijacked-ai-security-tools-at-90-organizations-the-next-wave-has-write-access-to-the-firewall>
- [31] UK AI Security Institute / Palo Alto Networks. “UK AISI + Palo Alto Networks — frontier models approaching autonomous enterprise intrusion in controlled testing.” 2026-05-01. <https://www.aisi.gov.uk/>